

Ransomware Attack Simulation & SOC Analysis Report

Corso: Cybersecurity Analyst

Modulo: W21D1

Studente: Emanuele Cestari

1. Obiettivo

L'obiettivo di questo report è simulare un attacco ransomware realistico contro un'azienda di medie dimensioni per analizzare il comportamento degli attaccanti, individuare vulnerabilità di sicurezza, valutare le capacità di incident response e migliorare la postura di cybersecurity dell'organizzazione.

La simulazione include:

- * social engineering,
- * phishing,
- * furto credenziali,
- * privilege escalation,
- * lateral movement,
- * data exfiltration,
- * distribuzione ransomware,
- * procedure di risposta organizzativa.

2. Prompt AI Utilizzato per la Simulazione

Simulare un attacco ransomware realistico contro una società di servizi finanziari con circa 200 dipendenti.

Lo scenario deve includere:

- * reconnaissance,
- * phishing attacks,
- * social engineering,
- * allegati malevoli,
- * privilege escalation,
- * credential dumping,
- * lateral movement,
- * data exfiltration,
- * distribuzione ransomware,
- * tentativi di estorsione.

Analizzare:

- * tattiche degli attaccanti,
- * sistemi compromessi,
- * interazione dei dipendenti,

- * impatto aziendale,
- * vulnerabilità di sicurezza,
- * opportunità di rilevamento.

Fornire:

- * raccomandazioni difensive,
- * procedure di incident response,
- * azioni di recovery organizzativa.

3. Executive Summary

Questo report analizza una campagna ransomware simulata eseguita da un gruppo threat actor motivato economicamente contro una società finanziaria.

L'attacco inizia tramite phishing e social engineering e si evolve in un incidente ransomware completo che include:

- * furto credenziali,
- * lateral movement,
- * data exfiltration,
- * cifratura dei sistemi critici.

La simulazione mostra come gli attaccanti sfruttino:

- * comportamento umano,
- * configurazioni deboli,
- * monitoraggio insufficiente,
- * segmentazione di rete inadeguata.

Il report evidenzia inoltre le attività di incident response e i controlli difensivi necessari per ridurre l'impatto operativo.

4. Fase 1 – Reconnaissance

L'attaccante inizia raccogliendo informazioni sull'organizzazione, sui dipendenti, sulle tecnologie utilizzate e sull'infrastruttura esposta.

Vengono analizzate fonti pubbliche come:

- * LinkedIn,
- * social media,
- * record DNS,
- * siti web aziendali.

L'obiettivo è identificare possibili target.

Gli attaccanti prendono di mira soprattutto dipendenti dei reparti finance e IT per via dei privilegi elevati e dell'accesso a sistemi sensibili.

Attività Individuate

- * Open-Source Intelligence (OSINT)
- * Profilazione social engineering
- * Raccolta email
- * Passive network reconnaissance
- * Enumerazione Shodan

Rischi Potenziali

- * Esposizione di informazioni sensibili sui dipendenti
- * Aumento del successo delle campagne phishing
- * Individuazione della superficie d'attacco esterna

5. Fase 2 – Initial Access

L'attaccante lancia una campagna spear-phishing mascherata da notifica interna del reparto IT.

L'email phishing contiene un allegato Microsoft Office malevolo con macro incorporate.

Una volta aperto dal dipendente, la macro scarica malware da un server Command and Control esterno e stabilisce l'accesso iniziale all'interno della rete.

Ulteriori vettori di accesso

- * VPN vulnerabili
- * Server RDP esposti
- * USB drop attacks

Tecniche Utilizzate

- * Spear-phishing attachment
- * Social engineering
- * Macro malevole
- * Credential harvesting

MITRE ATT&CK

- * T1566.001 – Spearphishing Attachment
- * T1190 – Exploit Public-Facing Application

6. Fase 3 – Persistence

Dopo aver ottenuto accesso, l'attaccante implementa meccanismi di persistenza per mantenere il controllo a lungo termine sui sistemi compromessi.

Tecniche Osservate

- * Registry Run Keys
- * Scheduled Tasks
- * Remote Access Trojans (RATs)
- * Script PowerShell di persistenza
- * Account amministratore nascosti

Rischi Potenziali

- * Accesso non autorizzato continuo
- * Difficoltà nella rimozione del malware
- * Attività di spionaggio a lungo termine

MITRE ATT&CK

- * T1053 – Scheduled Task
- * T1547 – Boot or Logon Autostart Execution

7. Fase 4 – Privilege Escalation

L'attaccante tenta di ottenere privilegi amministrativi utilizzando tecniche di credential theft ed exploitation.

Tool e Metodi

- * Mimikatz credential dumping
- * Pass-the-Hash attacks
- * Token impersonation
- * Exploitation vulnerabilità locali

Le credenziali compromesse permettono accesso a:

- * Domain Controllers
- * File Servers
- * Backup Servers
- * Database interni

MITRE ATT&CK

- * T1003 – OS Credential Dumping
- * T1075 – Pass the Hash

8. Fase 5 – Lateral Movement

L'attaccante si muove lateralmente nell'ambiente enterprise utilizzando tool di amministrazione remota e account compromessi.

Tecniche Osservate

- * Remote Desktop Protocol (RDP)
- * SMB shares
- * PsExec execution
- * PowerShell Remoting
- * Internal network scanning

Rischi Potenziali

- * Rapida propagazione del malware
- * Compromissione infrastrutture critiche
- * Infezione enterprise-wide

MITRE ATT&CK

- * T1021 – Remote Services
- * T1087 – Account Discovery

9. Fase 6 – Data Exfiltration

Prima della cifratura, l'attaccante ruba dati aziendali riservati tra cui:

- * dati clienti,
- * documenti finanziari,
- * report interni,
- * informazioni dipendenti.

I dati vengono compressi e trasferiti tramite canali cifrati verso infrastrutture esterne.

Tecniche Osservate

- * Traffico outbound cifrato
- * Abuso cloud storage
- * Archive staging
- * Trasferimenti file esterni

Rischi Potenziali

- * Violazioni normative
- * Danno reputazionale
- * Esposizione data breach

MITRE ATT&CK

- * T1041 – Exfiltration Over C2 Channel

* T1567 – Exfiltration to Cloud Storage

10. Fase 7 – Distribuzione Ransomware

La distribuzione automatizzata del ransomware inizia dopo che un numero sufficiente di sistemi è stato compromesso.

I sistemi critici diventano indisponibili mentre i file vengono cifrati e i meccanismi di recovery vengono disabilitati.

Attività Osservate

- * Eliminazione backup
- * Rimozione shadow copies
- * Interruzione servizi
- * Cifratura file
- * Distribuzione malware tramite Group Policy

Indicatori di Compromissione (IOC)

- * Estensioni .locked
- * Attività PowerShell anomala
- * Scheduled task sospetti
- * Modifiche massive ai file

MITRE ATT&CK

- * T1486 – Data Encrypted for Impact
- * T1490 – Inhibit System Recovery

Conclusione

Questo report dimostra come vulnerabilità tecniche, social engineering, phishing, configurazioni deboli e servizi esposti possano aumentare significativamente il rischio cyber in un ambiente enterprise.

Una combinazione di sviluppo sicuro, awareness dei dipendenti, monitoraggio continuo, visibilità SIEM e preparazione all'incident response è fondamentale per difendersi dalle moderne minacce informatiche.